

30 March 2026 | National Cyber Security Centre NCSC



Semi-Annual Report 2025/II (July – December)

Cybersecurity

Situation in Switzerland and internationally



Schweizerische Eidgenossenschaft
Confédération suisse
Confederazione Svizzera
Confederaziun svizra

Swiss Confederation

Federal Department of Defence,
Civil Protection and Sport DDPS
National Cyber Security Centre NCSC

Management Summary

In this semi-annual report, the National Cyber Security Centre (NCSC) presents the relevant incidents and developments in the context of cyberthreats against Switzerland and internationally. During the second half of 2025, the NCSC received 29,006 voluntary and 145 mandatory reports of cyber incidents. Of the reports received, 52% were classified as fraud; however, the number of fraudulent threat calls made in the name of authorities¹, which had dominated since mid-2023, declined significantly. While the core cyberthreat phenomena in Switzerland remained largely unchanged, the reporting period saw notable developments in how these threats were implemented and combined.

Phishing campaigns tailored to Switzerland

Cybercriminals continued to carry out voice phishing ('vishing') and real-time phishing² campaigns via fraudulent search engine advertisements. At the same time, more sophisticated and highly targeted approaches emerged, incorporating Swiss-specific features such as loyalty points programmes. Additionally, attackers increasingly relied on double phishing, exploiting a recent successful phishing incident to defraud its victims a second time over the phone.³ From summer 2025 onwards, criminals began using SMS blasters in Switzerland for the first time, enabling them to bypass the filtering mechanisms deployed by telecommunications providers to curb text message phishing.

Ransomware: A constant and serious threat

Ransomware and the associated extortion of stolen data continue to pose an opportunistic threat to all types of organisations in Switzerland.⁴ Akira was already the leading ransomware strain in Switzerland in the first half of 2025 and further intensified its activities during the reporting period. A key contributing factor was the exploitation of SonicWall devices, as corrective measures issued by the manufacturer following a vulnerability disclosed in 2024 were not consistently implemented by all affected organisations.

Attacks on international software supply chains

In the second half of 2025, many Swiss organisations were affected by vulnerabilities in widely used software products and compromises involving well-established, widely used components in open-source software (OSS). For example, in the context of the two Shai-Hulud campaigns in September and November 2025, more than a thousand npm (Node Package Manager) packages with monthly download figures in the hundreds of millions were infected. Such complex technical dependencies place significant demands on those responsible for IT security, as a vulnerability in these software libraries can potentially expose all applications incorporating the affected component in their code.

¹ [Calls in the name of fake authorities \(ncsc.admin.ch\)](https://ncsc.admin.ch/calls-in-the-name-of-fake-authorities)

² [Phishing, vishing, smishing \(ncsc.admin.ch\)](https://ncsc.admin.ch/phishing-vishing-smishing)

³ [Week 39: When one phishing attempt follows another \(ncsc.admin.ch\)](https://ncsc.admin.ch/week-39-when-one-phishing-attempt-follows-another)

⁴ [Ransomware \(ncsc.admin.ch\)](https://ncsc.admin.ch/ransomware)

ORB networks in Switzerland

The number of compromised devices being used in covert Operational Relay Box (ORB) networks continues to grow. These networks usually comprise internet-connected devices (Internet of Things, IoT) and routers that have been infected with malware⁵. These devices are then used to carry out various types of attack, while also undermining the privacy of their owners. As a result, a significant number of devices belonging to individuals and organisations in Switzerland have been misused to carry out attacks against third-party targets. For this reason, regularly updating devices exposed to the internet is key to combatting such networks. As early as 2024, international observations showed that state-supported actors were also using infrastructures such as ORB networks for espionage and sabotage activities.

Further sections of the semi-annual report examine observations and developments relating to malware, attacks affecting the availability of websites and web services, data management, as well as cyber espionage and sabotage. Despite an increasingly tense geopolitical environment, the impact of the cyberthreat landscape on Switzerland remains relatively stable overall, and cyber resilience can be assessed as largely robust.

⁵ [Malware \(ncsc.admin.ch\)](https://ncsc.admin.ch)

Contents

	Editorial	4
1	Cyberthreats in Switzerland: An overview	6
2	Phishing	9
3	Malware	14
	3.1 Initial access with malware	14
	3.2 Ransomware	16
	3.3 Covert ORB networks in Switzerland	19
4	Vulnerabilities	20
5	Fraud and social engineering	21
6	Attacks on the availability of websites and webservice	25
7	Data management, leaks and extortion	26
8	Cyberespionage and cybersabotage	28
	8.1 Cyberespionage	28
	8.2 Threats to industrial control systems and operational technology	30

Editorial

The level of cyberthreats in Switzerland remains high. As in previous periods, the majority of detected cyber incidents are attributable to criminal activity. However, economic uncertainty and an increasingly tense geopolitical environment are leading to more targeted, coordinated and effective cyberattacks. Alongside the persistent threat posed by cybercrime, organisations must also contend with increasingly sophisticated attacks by state-sponsored actors pursuing strategic interests.

Ransomware attacks continue to be one of the most significant challenges for organisations in Switzerland. The combination of system encryption and data extortion remains a serious risk for both private businesses and public authorities. In recent months, for example, the hacker group Akira has significantly expanded its activities in Switzerland. Additionally, attacks targeting supply chains are increasing, online advertising is being increasingly exploited for deceptive and fraudulent purposes, and ongoing digitalisation is leading to a growing number of vulnerabilities that could be exploited. Together, these developments are expanding the attack surface and increasing the overall complexity of the threat landscape.

A realistic and reliable assessment of this situation is only possible if cyber incidents are reported consistently and analysed systematically. This semi-annual report is based on the large number of voluntary reports submitted by the public and by businesses, which form an indispensable foundation for the national cyberthreat picture. Around 65,000 such reports were received by the NCSC in the past year. The introduction of mandatory reporting for operators of critical infrastructure on 1 April 2025 was an important step towards strengthening national cyber resilience. For the first time, reportable incidents can now be systematically incorporated into the analysis.

The reports received to date have provided valuable insights into attack methods, affected sectors, and potential systemic risks. Analysis of these reports clearly shows that cybersecurity is not an isolated task for individual actors. The state, the private sector and wider society are all affected and must all take action. Cyberattacks do not stop at organisational, industry or national borders; instead, their impact unfolds along digital interdependencies.

Against this backdrop, geopolitical issues have been discussed with increasing intensity both nationally and internationally. In particular, these discussions have focused on the growing systemic relevance of digital dependencies, the influence of new technologies such as artificial intelligence, and the need for coordinated action between states, supervisory authorities, and private actors.

One recurring conclusion from these discussions is that cyber resilience requires more than just prevention. In addition to technical security measures, it calls for clear governance structures, effective response and recovery capabilities, and close cooperation within Switzerland and beyond. We therefore intend to continue investing in this area, with a view to simplifying cooperation further and taking a more united and proactive approach to combatting cyberthreats.

The NCSC would like to thank all organisations and individuals whose contributions to the National Cyber Strategy (NCS) and reports of cybersecurity incidents or threats, as well as

their engagement with and interest in cybersecurity, have played a substantial role in strengthening national cyber resilience. This collective effort is essential if Switzerland is to continue to address the challenges of cyberspace effectively in future.

Florian Schütz, Director of the National Cyber Security Centre

1 Cyberthreats in Switzerland: An overview

A key feature of the digital space is that cyberattacks can be carried out remotely across national borders. With the emergence of SMS blasters in Switzerland in summer 2025, however, attackers deliberately chose to forgo this advantage of physical distance between attacker and target.⁶ Due to strengthened filtering measures introduced by telecommunications providers to combat phishing attacks, criminals started using portable, backpack-sized mobile antennas in Swiss cities to send fraudulent text messages to mobile phones within a radius of up to one kilometre (see Section 2). This clearly shows that cybercriminals continue to look for new tactics to achieve their aims – even if that means exposing themselves in public spaces. The cyberthreat landscape is therefore a dynamic environment in which both attackers and defenders must continually adapt their approach to changing circumstances.

When describing the cyberthreat landscape, the Semi-Annual Report primarily relies on voluntary reports submitted to the NCSC by members of the public and businesses. However, the second half of 2025 marks the first time that mandatory incident reports from critical infrastructure operators are included. The reporting obligation for critical infrastructure operators was introduced on 1 April 2025.⁷ In total, the NCSC processed 145 reportable cyber incidents during the reporting period. These incidents were spread across various sectors, with the highest number of reports coming from the public sector (25%), IT and telecommunications (18%), and the financial and insurance sector (15.7%) (see fig. 1). The most common attack types involved unauthorised access to systems (hacking), theft of access credentials, and attacks on availability (DDoS)⁸. Disruptive tactics such as encryption and extortion (ransomware) were present in around 7% of cases (see fig 2).

Voluntary reporting increased slightly over 2025 as a whole, rising to 64,733 reports compared with 62,954 cyber incidents reported the previous year. Of these, 29,006 reports were received in the second half of 2025 (see fig. 3). Fraud was again the most frequently reported category, with 15,090 reports, followed by phishing (6,299) and spam (4,284). A notable development was the increase in reports of advertising for online investment fraud, which is categorised as spam. Although reports increased by more than 2,500 compared to the second half of 2024, the overall rise in 2025 was primarily driven by the first half of the year, levelling off again in the second. There was also an increase in reports relating to fraudulent online shops that either deliver no goods or deliver poor-quality goods. Notably, many of these websites emphasise Swiss-specific features to build trust with customers.

By contrast, reports of fraudulent threat calls made in the name of authorities fell from 8,173 in the second half of 2024 to 5,941 in the reporting period.⁹ For the first time since this category emerged in the second half of 2023, reports have clearly declined. The number of reports of online investment fraud remained stable at 430 cases, compared with the first half of the year.¹⁰

⁶ [Week 36: New risk from "SMS blasters" \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/Week-36-New-risk-from-SMS-blasters)

⁷ [Information on the reporting obligation \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/information-on-the-reporting-obligation)

⁸ [Attack on availability \(DDoS\) \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/Attack-on-availability-DDoS)

⁹ To provide more information on threatening scam calls purporting to be from the authorities, the NCSC published a [supplementary report](#) alongside the [Semi-Annual Report 2024/1](#).

¹⁰ [Online Investment fraud \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/Online-Investment-fraud)

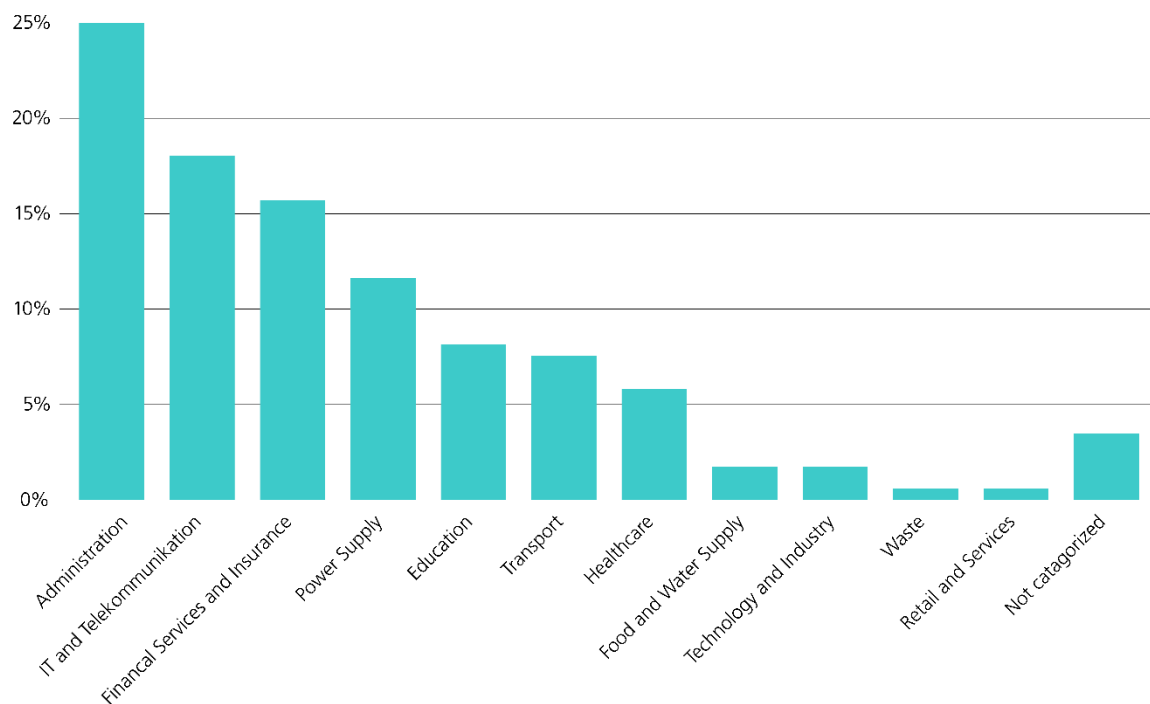


Fig. 1: Percentage distribution of reportable cyber incidents reported to the NCSC by sector in the second half of 2025

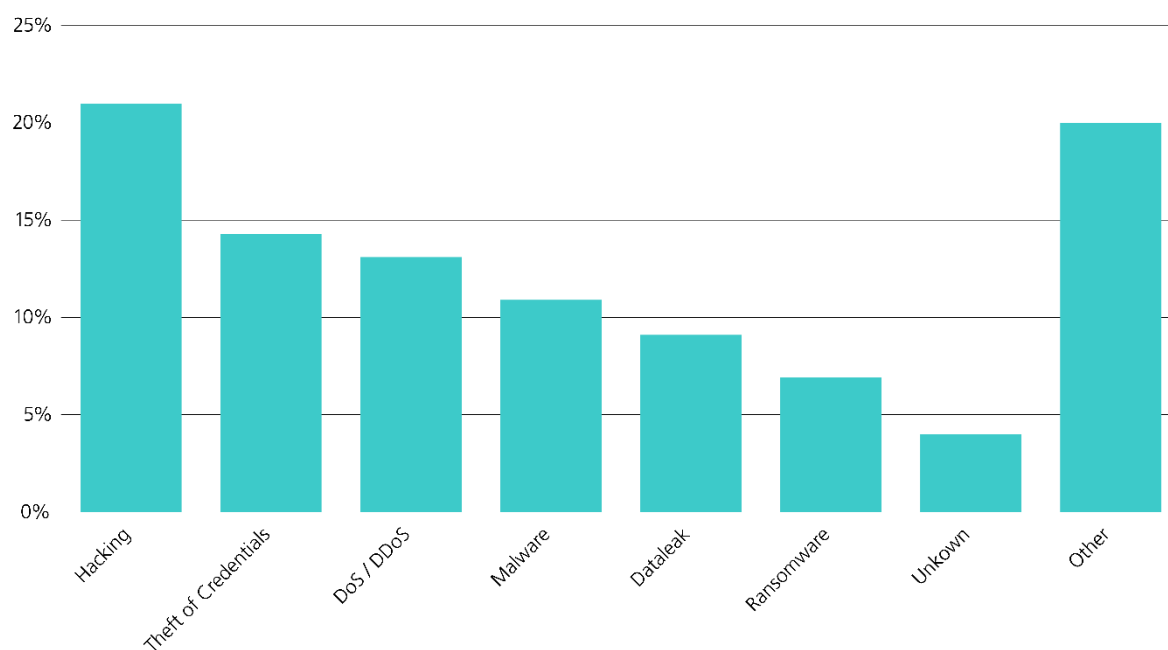


Fig. 2: Percentage distribution of reportable cyber incidents reported to the NCSC by attack type in the second half of 2025

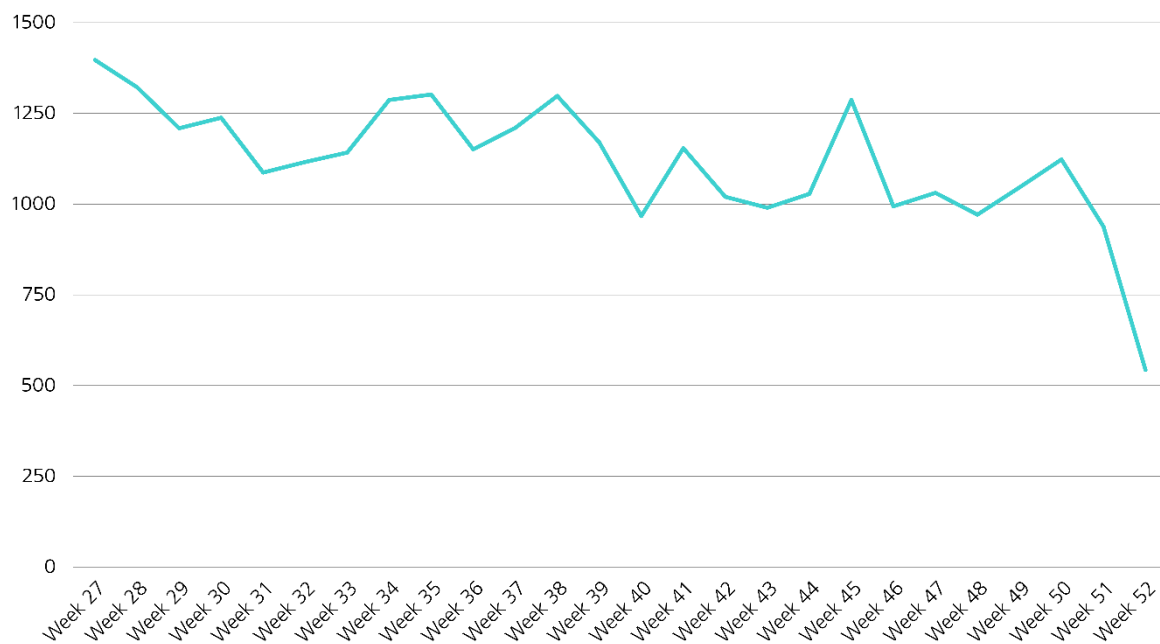


Fig. 3: Voluntary reports to the NCSC per week in the second half of 2025, see [Current figures \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/current-figures)

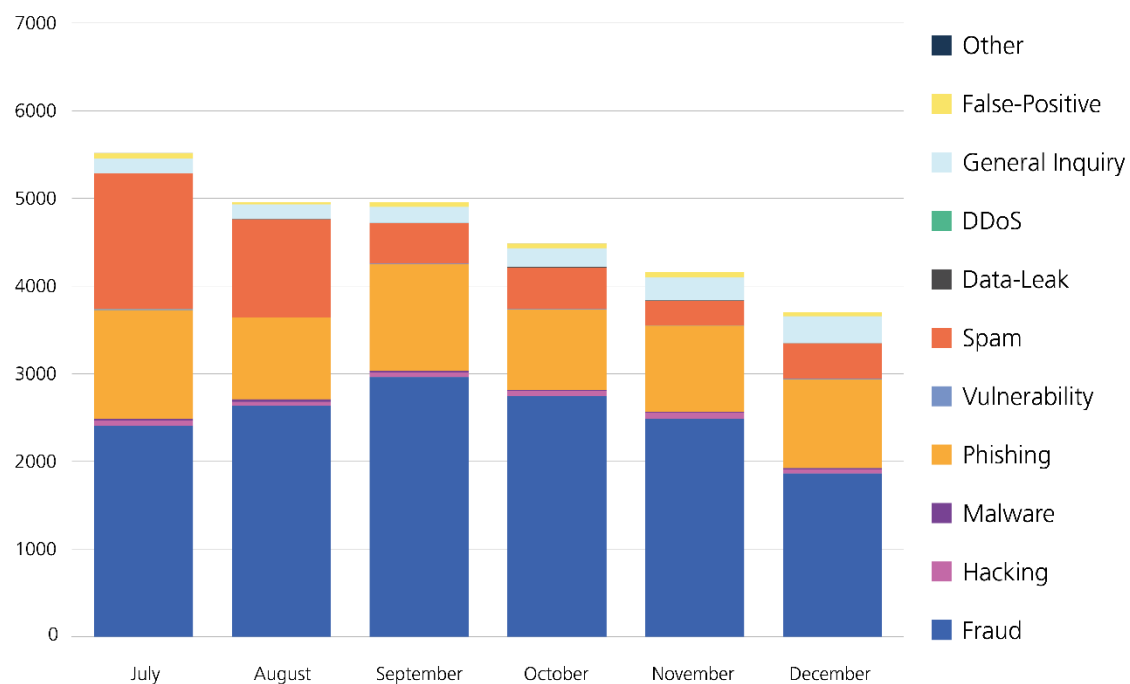


Fig. 4: Voluntary reports to the NCSC in the second half of 2025 by category, see [Current figures \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/current-figures)

However, there was an increase in reports of victims being contacted again after online investment fraud, supposedly to recover the stolen money.

The proportion of voluntary reports submitted by the public (90%) and by companies, associations and public authorities (10%) remains unchanged. While businesses and private individuals alike are affected by fraudulent threat calls and phishing attempts, 57 companies reported being confronted with ransomware in the second half of 2025. Typical scams targeting organisations continue to include business email compromise (BEC)¹¹ and CEO fraud¹². While reports of CEO fraud fell again after an increase in the first half of 2025, invoice manipulation fraud continues to show an upward trend: after 59 reports in the first half of 2025, 73 cases were recorded in the second half. This type of fraud can result in substantial financial losses. In one case, for example, criminals stole CHF 1.5 million. Furthermore, this approach can grant attackers access to confidential company communications, which could have severe ramifications for third parties.

The statistics show that cybersecurity and protecting Switzerland from cyber risks is an ongoing challenge for business, government and society. This semi-annual report therefore sets out the main areas that define Switzerland's cyberthreat landscape: phishing, malware, vulnerabilities, fraud, social engineering¹³, distributed denial-of-service (DDoS) attacks on websites and other online services, data leaks, and cyberespionage and cybersabotage. The report focuses primarily on incidents and developments in Switzerland, but it also refers to international trends where these help to illustrate the situation in Switzerland (see Section 8). The topic-based sections provide an overview of current forms of these threats, noteworthy incidents and key developments. In line with the principle of shared responsibility for a safer digital Switzerland, the report provides the public with recommendations on how to respond to these challenges.

2 Phishing

Phishing enables attackers to collect login credentials, financial details, and other confidential information without the user's knowledge. Typically, social engineering plays a central role in influencing recipients while no malware is distributed.¹⁴ The classic approach involves sending a message containing a link to a large number of recipients. The link leads to a phishing website that is designed to resemble a legitimate site. If recipients believe the phishing website is genuine, they enter sensitive information – such as e.g. login or credit card details – which then goes straight to the phishers. Although email remains the most common method of phishing, other approaches use phone calls (voice phishing, or 'vishing'), text messages (SMS phishing, or 'smishing'), or other types of mobile messaging to obtain information. When phishing is directed at a specific person or selected group of people, it is referred to as 'spear-

¹¹ [Business Email Compromise \(BEC\) \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/news/2025/01/business-email-compromise-bec)

¹² [CEO fraud \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/news/2025/01/ceo-fraud)

¹³ [Social engineering \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/news/2025/01/social-engineering)

¹⁴ There is no single international definition of phishing, so other definitions often include the distribution of malware (see [Phishing \(attack.mitre.org\)](https://attack.mitre.org/wiki/Phishing)). The NCSC explicitly excludes this aspect in the definition it applies.

phishing'. Unlike the mass-distributed form, spear phishing is much harder for victims to detect since it is tailored to them.

In 2025, the NCSC received 12,280 reports of phishing attempts via the public reporting form, which is an almost unchanged figure compared with the previous year. Of these, 6,299 reports were submitted in the second half of the year, which is a slight increase of 903 reports compared to the same period the previous year.

A different picture emerges from reports submitted via the NCSC's antiphishing.ch platform.¹⁵ Following several periods of steady growth up to the end of 2024, a decline was observed in 2025. While 9,355 unique phishing URLs were reported in the second half of 2024, this figure fell to 7,969 in the same period in 2025. To make phishing sites appear as convincing as possible, attackers often impersonate well-known brands and companies to lure victims. The most frequently targeted in this reporting period were postal services (24%), public transport (20%), the financial sector (19%), the IT sector (7%) and the insurance sector (7%) (see fig. 5). In addition to the continued increase in phishing attempts linked to health insurers, the number of reported phishing URLs in the retail sector rose by 5%.¹⁶

Overall, the second half of 2025 shows a continuation of developments already observed in the first half of the year. Impersonal phishing messages sent in large volumes remain widespread. Around 40% of all phishing URLs are still related to SwissPass and parcel delivery services. At the same time, attackers are increasingly using more elaborate and targeted approaches, which require greater effort. Reports of real-time phishing targeting bank customers via malicious advertising in search engines continued.¹⁷ However, as awareness increased, phishers adjusted their distribution methods, moving away from relying solely on paid advertisements and increasingly using SEO poisoning instead.¹⁸ Vishing continues to be used too, with victims contacted by email or text message about alleged e-banking transactions and prompted to call back if there is an error.¹⁹ At the same time, phishers increasingly exploited the heightened security awareness among people in Switzerland by disguising phishing messages as verification emails.²⁰ Victims were asked to confirm their identity by entering their login details on a phishing website. In addition to these developments, several incidents involving SMS blasters²¹ and double phishing²² – a newly observed phishing method – were recorded in Switzerland.

¹⁵ The NCSC receives phishing reports in the form of incident reports, as well as via the antiphishing.ch website, which draws on additional sources. As a result, the figures presented here may differ from the number of direct phishing reports.

¹⁶ See, for example, [Phishing-Mail richtet sich an Helsana-Kunden \(cybercrimepolice.ch\)](https://cybercrimepolice.ch/Phishing-Mail-richtet-sich-an-Helsana-Kunden), [Phishing email – CSS health insurance refund \(cybercrimepolice.ch\)](https://cybercrimepolice.ch/Phishing-email-CSS-health-insurance-refund)

¹⁷ See [Semi-Annual Report 2025/1](#), Section 2.

¹⁸ In SEO poisoning, attackers attempt to manipulate search engines so that their malicious websites appear first in the most relevant results (see [Search engine optimisation poisoning \(cyber.gc.ca\)](https://cyber.gc.ca/Search-engine-optimisation-poisoning)).

¹⁹ [Week 50: Recall with financial consequences \(ncsc.admin.ch\)](https://ncsc.admin.ch/Week-50-Recall-with-financial-consequences)

²⁰ See, for example, [Week 48: Phishing impersonating SERAFE under the pretext of "residence verification" \(ncsc.admin.ch\)](https://ncsc.admin.ch/Week-48-Phishing-impersonating-SERAFE-under-the-pretext-of-residence-verification)

²¹ [Week 46: How fraudsters bypass providers' SMS filters \(ncsc.admin.ch\)](https://ncsc.admin.ch/Week-46-How-fraudsters-bypass-providers-SMS-filters)

²² [Week 39: One phishing attempt follows another \(ncsc.admin.ch\)](https://ncsc.admin.ch/Week-39-One-phishing-attempt-follows-another)

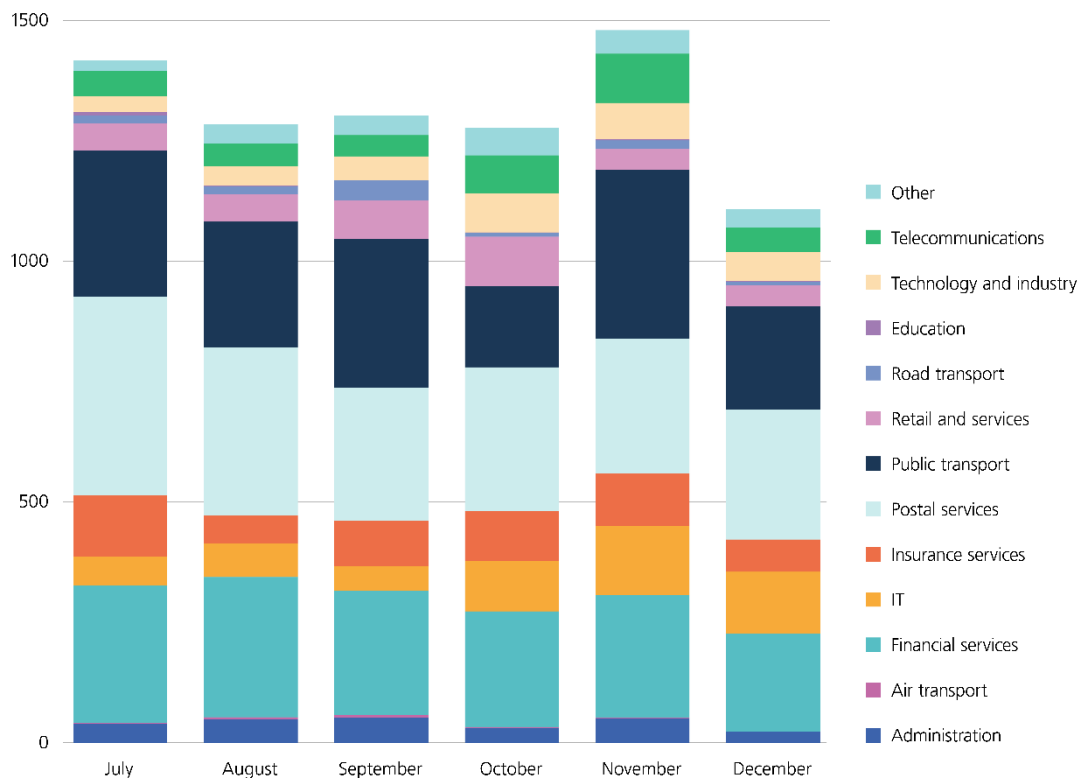


Fig. 5: Number of phishing URLs confirmed by the NCSC, by sector of impersonated brands, in the second half of 2025

Recommendations

Report suspicious phishing attempts to the NCSC via reports@antiphishing.ch or directly via the website antiphishing.ch. If you would like feedback, you can also report the phishing incident using the [report form](#) or by contacting the NCSC's specialists at incidents@ncsc.ch. By doing so, you help the NCSC to issue targeted warnings and take action to ensure that fraudulent websites can be blocked.

Phishing campaigns tailored to Switzerland

In the second half of 2025, attackers increasingly carried out targeted phishing attacks using content typically associated with Switzerland or aimed at specific groups of people. Compared with impersonal mass phishing, this approach increases the likelihood of success for the phishers. One example was an email campaign informing older people about allegedly unclaimed pension funds. Other phishing campaigns made use of data from older data breaches (see Section 7) in order to make fraudulent messages appear more credible by including sensitive information relating to the recipient. In another case, attackers targeted Swisscom customers directly. Instead of the usual phishing refund emails, recipients were warned that their loyalty points were about to expire. A carefully designed, fully functional website led recipients to believe that they had 8,517 loyalty points available. Victims could add items such as bicycles or smartphones to a shopping basket until the points were used up. To redeem the loyalty points, however, they were required to pay fees and provide sensitive personal data for the purported

products.²³ This approach is effective because it plays on people's fear of missing out. Similar campaigns have also been observed in other sectors with comparable loyalty schemes, including Swiss supermarkets, banks, and credit card companies.

Comprehensive data profiles built through phishing

In addition to traditional phishing campaigns targeting login credentials or credit card information, the NCSC observed numerous attacks in which far more extensive data was requested. In these cases, the attackers created websites designed to resemble those of trusted institutions, such as banks, insurers, health insurers, and other payment service providers. Under the pretext of verifying or updating data, individuals were prompted to disclose extensive personal information. In one case, attackers even requested a digital signature in connection with an alleged refund.

The aim of these attacks is to compile comprehensive data profiles of victims. Such profiles are particularly valuable for criminal activities, as they can be used for identity theft and social engineering attacks, or sold on the black market: the more comprehensive the profile, the higher is its value. These attacks reflect a broader shift from generic mass phishing to more targeted approaches, where even small details such as correct forms of address can increase trust. If attackers also know bank details or other personal circumstances, victims are even more likely to enter their data.

Double phishing

During the reporting period, the NCSC received reports of more complex phishing attacks, which further highlights the trend towards increasingly targeted and sophisticated methods. In double phishing, attackers use a multi-stage approach, immediately reusing data obtained during an initial successful phishing attempt for a subsequent phishing attack. First, victims received a conventional phishing email containing a link to a phishing website. This email was often related to an alleged tax refund or parking fine. Besides credit card details, they were asked to provide their bank's name and their telephone number. Shortly afterwards, the attackers called the victim using the provided phone number and posed as a security department of the financial institution in question. They claimed that the account had just been compromised or that funds had been transferred without authorisation. In order to protect the account, the victim was instructed to grant immediate remote access to their computer. In reality, this access was then used to carry out transactions via the victim's online banking account.

Thanks to strengthened security measures implemented by banks, direct attacks on e-banking accounts have become less common. Consequently, attackers are increasingly persuading victims to hand over control themselves, thereby circumventing established security measures. For victims, the phone call appears plausible because the security incident triggered by the initial phishing attempt has in fact occurred. This method illustrates how phishers combine written and telephone-based attacks to appear more credible and maximise their profits. Similar approaches have also been observed in phishing campaigns involving parking fines and online classified adverts. Language barriers can still present an obstacle in telephone-based attacks: in one reported case, the attackers could only communicate in French. However, with the growing use of artificial intelligence (AI), language barriers are expected to become less relevant in future, as calls can be made using real-time translation tools.

²³ [Phishing-SMS lockt mit angeblichen Cumulus-Punkten \(cybercrimepolice.ch\)](https://www.cybercrimepolice.ch/en/press-releases/2023/04/phishing-sms-lockt-mit-angeblichen-cumulus-punkten)

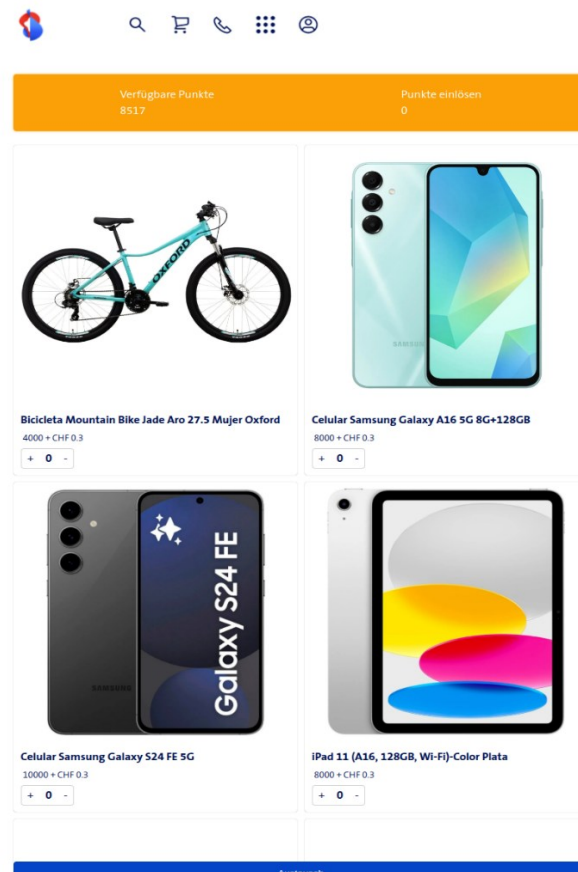


Fig. 6: Phishing website with alleged Swisscom loyalty points

SMS blaster

In late summer 2025, a new method of distributing phishing and fraudulent messages was observed in Switzerland for the first time: SMS blasters.²⁴ Although this technique had already been seen in parts of Europe and Asia, it represented a new distribution method in Switzerland and required close cooperation between the authorities and telecommunications providers to mitigate it. A SMS blaster is a portable, pocket-sized device that mimics a mobile network antenna, causing nearby mobile phones to connect to it. Once a connection has been established, the target device is forced to downgrade to the outdated 2G protocol. When the device is operating in 2G mode, attackers exploit a known vulnerability – a null cipher – to deliver text messages without the usual checks and without involving the legitimate telecommunications provider. This allows attackers to send phishing text messages (smishing) to mobile devices within a radius of up to one kilometre, bypassing the standard blocking filters and detection mechanisms used by network providers to identify and prevent phishing attempts. The content of the messages and the linked websites follow phishing patterns already known to the NCSC, such as impersonating delivery services, threatening fines or advertising attractive loyalty rewards in order to obtain login credentials or credit card information.

²⁴ [Week 46: How fraudsters bypass providers' SMS filters \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/News/2025/07/Week-46:-How-fraudsters-bypass-providers-SMS-filters.html)



Recommendations

Wherever possible, enable multi factor authentication (MFA) as an additional security measure for your accounts. Although MFA reduces the risk of your account being compromised, it can still be bypassed using social engineering.²⁵ So be wary of fake requests, especially via email and text message when you are asked to confirm access or forward your security token to someone else. Remember that email addresses and phone numbers can easily be spoofed to make messages appear more credible. Never enter credit card details or other sensitive data on a website that you have accessed via a link in an email or text message.

3 Malware

Malware is a primary tool that attackers use to gain access to devices or networks. As a rule, such programs execute unwanted and usually harmful functions on IT systems without the user's knowledge.²⁶ This can include stealing, altering and/or destroying data. Malware infections can occur in various ways via different channels, and any type of device or infrastructure can be affected.

3.1 Initial access with malware

Initial access describes all actions an attacker must take to compromise another system. This can be achieved by obtaining login credentials, such as usernames and passwords, through social engineering and phishing (see Section 2), by exploiting vulnerabilities (see Section 4), or by using malware, such as trojans. The latter usually requires the user to execute an action and relies on various deception mechanisms (social engineering) to trick victims into installing the malware. For instance, the malware may be concealed within another program, email attachment, or link that seems harmless at first glance.

During the reporting period, the NCSC did not identify any new methods of distributing malware. Most of the campaigns reported in Switzerland mirrored international developments and showed no characteristics specific to Switzerland. The ClickFix method, whereby victims are tricked into installing malware themselves, continues to be used extensively by cybercriminals and was described in previous semi-annual reports.²⁷ This indicates that the cost-benefit ratio of this approach remains favourable for attackers. Attackers continue to act primarily opportunistically, seeking to infect as many devices as possible without targeting specific groups or

²⁵ [Social Engineering \(ncsc.admin.ch\)](#)

²⁶ [Malware \(ncsc.admin.ch\)](#)

²⁷ See [Semi-Annual Report 2024/2](#), Section 3.1; [Semi-Annual Report 2025/1](#), Section 3.1.

sectors. In some cases, however, targeted adjustments were observed that were intended to increase credibility among people in Switzerland.

In several cases, fake invoices were sent by email, purportedly from debt collection companies operating in Switzerland. These emails included an attached QR-bill and instructed recipients to make a payment. When opened, the attachment – an HTML file – displayed an error message stating that the PDF could not be shown because JavaScript was disabled. Recipients were then instructed to press the Windows+R key combination, followed by Ctrl+V. As with the ClickFix method, this launched a malicious script that had been copied to the clipboard in advance, resulting in the installation of malware.²⁸ The NCSC also received multiple reports relating to online classified ad platforms. In these cases, the criminals posed as buyers claiming to be in a hurry and said that payment had already been made. They attached a file named 'twint-rechnung.zip' to the email. This file contained malware (infostealer) designed to steal personal or financial data, primarily extracting login credentials stored in the browser.²⁹ Several attacks were also carried out via fake recruitment processes, mainly through LinkedIn.³⁰ In one case, a technical issue was simulated during the upload of an application video, after which the applicant was instructed to execute a command that had been copied to the clipboard – again a ClickFix approach. In another case, applicants were asked to download files as part of a purported programming task. These files contained malicious code that stole sensitive data from the applicant's computer. The two approaches described above are also commonly observed internationally and are considered to be typical methods employed by state-controlled North Korean actors (see Section 8). These groups primarily target employees of companies operating in the cryptocurrency or blockchain sector, including in Switzerland.³¹

Alongside these targeted attacks, numerous incidents linked to international campaigns were observed that did not specifically target Switzerland. The NCSC continues to detect malvertising – malicious advertising in search engine results.³² In one case, this attack vector led to an infection that ultimately resulted in a ransomware attack.³³ In other cases, malware was disguised as seemingly useful software, such as a PDF editor. In these cases, the malicious code only activated several months after installation, during which time the application appeared to operate normally, leading it to be perceived as legitimate.³⁴

Several attacks on the software supply chain were also observed. In these cases, accounts belonging to package managers on open-source development platforms (e.g. GitHub, npm) were compromised, allowing attackers to introduce malicious code into widely used components. These incidents included the compromise of the developer account Qix, which enabled manipulated versions of dozens of commonly used libraries to be published.³⁵ In addition, during the large-scale Shai-Hulud 2.0 campaign, attackers altered hundreds of components from

²⁸ [Week 33: Cybercriminals use social engineering to spread malware \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/Week-33-Cybercriminals-use-social-engineering-to-spread-malware)

²⁹ [Week 40: Classifieds phishing – shifting from links to malware \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/Week-40-Classifieds-phishing-shifting-from-links-to-malware)

³⁰ [Week 49: The hidden risks of enticing employment opportunities - How job seekers fall into the malware trap \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/Week-49-The-hidden-risks-of-enticing-employment-opportunities-How-job-seekers-fall-into-the-malware-trap)

³¹ [Analysis of Contagious Interview Campaigns by North Korean Threat Actors \(sentinelone.com\)](https://www.sentinelone.com/blog/analysis-of-contagious-interview-campaigns-by-north-korean-threat-actors)

³² See [Semi-Annual Report 2025/1](#), Section 3.3.

³³ [From Bing Search to Ransomware: Bumblebee and AdaptixC2 Deliver Akira \(thedfirreport.com\)](https://thedfirreport.com/From-Bing-Search-to-Ransomware-Bumblebee-and-AdaptixC2-Deliver-Akira)

³⁴ [TamperedChef: Malvertising to Credential Theft \(labs.withsecure.com\)](https://labs.withsecure.com/tamperedchef-malvertising-to-credential-theft)

³⁵ [Dev snared in crypto phishing net, 18 npm packages compromised \(theregister.com\)](https://theregister.com/dev-snared-in-crypto-phishing-net-18-npm-packages-compromised)

open-source projects so that malicious code was automatically executed upon installation.³⁶ This campaign enabled attackers to steal sensitive data and move laterally from one developer account to another using compromised credentials.



Recommendations

Never click on links, open attached files, or scan QR codes in suspicious messages. If in doubt, contact the purported sender via a trusted channel to verify that the message is really from them. Always be suspicious when a download window pops up.

When searching for software, download it only from the product's official website or from a reputable download site. Pay attention to whether a search result is marked as paid advertising and treat these results with caution, as attackers often use them to appear at the top of search listings.

Regularly patch your systems and restrict access rights as much as possible. If you suspect an infection, have your computer examined immediately by a specialist and cleaned if necessary. The safest option is to completely reinstall the operating system of your computer. However, do not forget to back up all personal data beforehand.

3.2 Ransomware

Ransomware is an attack type in which criminals deploy malware to encrypt data on a victim's IT systems, rendering it unusable.³⁷ Typically, they take a copy of the data before encryption and demand a ransom afterwards. The criminals promise to provide a decryptor if the victim pays. If the victims do not react to the demands, they threaten to publish the stolen data if it refuses to pay the ransom. Ransomware groups often increase the pressure – for example by contacting the victim's customers and suppliers and threatening to publish the stolen data – to push the victim to a payment.

In the second half of 2025, the NCSC recorded 79 ransomware incidents involving organisations in Switzerland (see fig. 7). The statistical increase (there had been 57 reports in the first half of 2025 and 47 cases in the second half of 2024) is due to an adjustment in the NCSC's internal methodology. This report now considers not only the 47 cases voluntarily reported to the NCSC's contact point for cyber incidents, but also the 10 cases reported under the mandatory reporting obligation for cyberattacks on critical infrastructures and the 22 cases of ransomware of which the NCSC became aware through national partners. The number of incidents voluntarily reported to the National Cyber Risks Reporting Office therefore remained stable. Nevertheless, the actual number of ransomware incidents in Switzerland is likely to be

³⁶ [Shai-Hulud 2.0 Supply Chain Attack \(wiz.io\)](https://wiz.io)

³⁷ [Ransomware \(ncsc.admin.ch\)](https://ncsc.admin.ch)

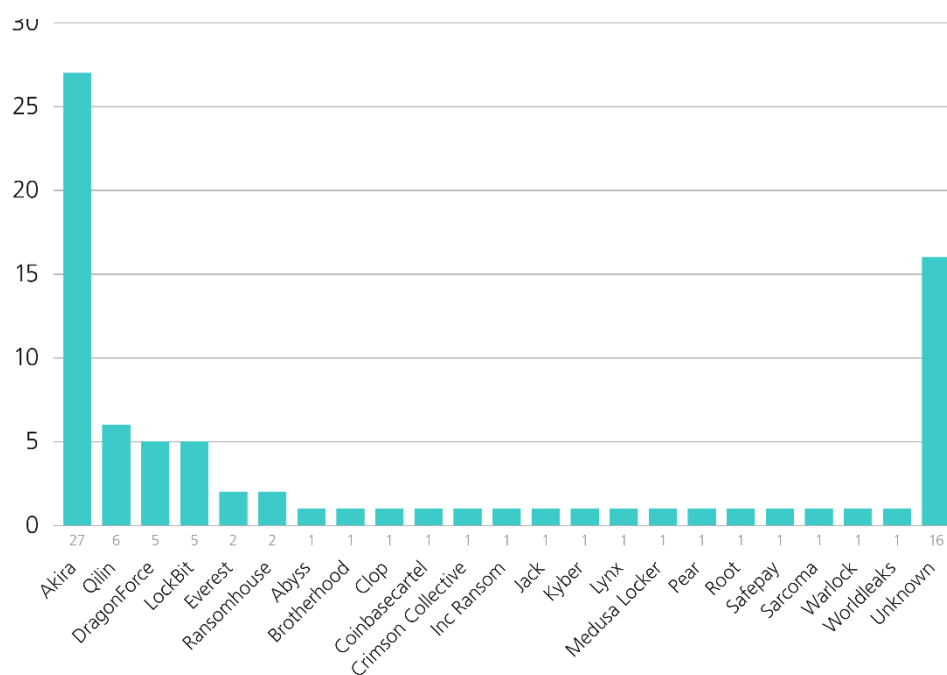


Fig. 7: Number of extortion incidents reported to and observed by the NCSC in the context of operating ransomware groups in the second half of 2025

higher than the 79 cases observed by the NCSC overall, as not all affected organisations report incidents, and not all cases become publicly known.

The most active ransomware group in Switzerland during the second half of 2025 was once again Akira. Already the leading group in the first half of 2025, it further intensified its activities, increasing from 7 to 26 attacks known to the NCSC.³⁸ Akira is also among the most active ransomware groups internationally and targets organisations of all sizes and across all sectors. During the reporting period, attacks by this group particularly affected organisations using SonicWall devices. Initial assumptions pointed to the exploitation of a zero-day vulnerability (see Section 4). However, subsequent analysis showed that attackers were exploiting an older vulnerability that had been disclosed in August 2024, for which a security update was available. Many organisations had not fully implemented the provided corrective measures. As a result, Akira was able to gain initial access with extensive privileges using still-valid credentials, which facilitated the spread of its ransomware.³⁹

Qilin, DragonForce and LockBit were also among the most active groups in Switzerland, with five to six successful attacks each. In September 2025, DragonForce announced that the three groups would form an alliance. Three months later, however, this appeared to be more of a strategy to recruit new affiliates than a genuine operational collaboration.⁴⁰ Qilin claimed responsibility for more than 700 attacks worldwide during the reporting period, making it the most active group globally. This high level of activity is linked to its ransomware-as-a-service (RaaS) model. In this model, ransomware developers provide a ready-to-use platform that enables

³⁸ [Cybercrime: the AKIRA group steps up its activities \(admin.ch\)](https://www.admin.ch/cybercrime/akira-group-steps-up-its-activities)

³⁹ [Akira Ransomware Group Utilizing SonicWall Devices for Initial Access \(rapid7.com\)](https://www.rapid7.com/news/akira-ransomware-group-utilizing-sonicwall-devices-for-initial-access)

⁴⁰ [In depth analysis of the alleged Qilin, DragonForce and LockBit alliance \(yarix.com\)](https://www.yarix.com/en/in-depth-analysis-of-the-alleged-qilin-dragonforce-and-lockbit-alliance)

affiliates to carry out ransomware attacks, exfiltrate and publish data, and conduct negotiations in exchange for a share of the ransom. The particularly high number of victims attributed to Qilin suggests that its RaaS model has gained traction among affiliates.⁴¹ As part of this model, the group has established a legal service that analyses stolen data in light of regulatory requirements. This allows Qilin's partners to increase pressure during negotiations by pointing to compliance risks and the possibility of prosecution. In contrast, LockBit's activity declined sharply in 2025 due to several international law enforcement operations and internal data leaks.⁴² In September 2025, those responsible announced a new version of their ransomware: LockBit 5.0. More than 100 victims were attributed to this version in December 2025 alone, including one in Switzerland. This suggests that the group may have succeeded in recruiting new affiliates and resuming its operations.

Several major international incidents during the reporting period illustrated the potential scale of ransomware attacks. For example, an incident involving Jaguar Land Rover in the UK led to a production stoppage lasting several weeks, affecting more than 5,000 companies across the supply chain. Direct intervention by the UK government in the form of a GBP 1.5 billion credit guarantee was required, and the total economic damage is estimated at almost GBP 1.9 billion.⁴³ Other organisations, such as Collins Aerospace, were also affected by ransomware. In this case, compromises at several European airports disrupted air traffic, including a check-in system used by numerous airlines that was unavailable for several days as a result of the cyberattack.⁴⁴

No incidents of comparable scale were observed in Switzerland during the reporting period. Nevertheless, the threat posed by ransomware remains high, reinforced by groups capable of rapidly exploiting vulnerabilities or compromised access. Although none of the known groups specifically target Swiss organisations, opportunistic attacks are commonplace and therefore affect Switzerland too.

Recommendations

On the NCSC website, you find a [list of preventive measures](#) to protect against ransomware as well as [guidance on what to do in the event of an incident](#). It is essential to provide staff with training and exercises on how to handle IT outages, in order to ensure a fast and effective response in an emergency. In general, the NCSC and its international partners advise ransomware victims not to pay.⁴⁵ There is no guarantee that cybercriminals will keep their word. Paying the ransom only serves to fund their operations and enable further attacks.

⁴¹ [The Evolution of Qilin RaaS \(sans.org\)](#)

⁴² See [Semi-Annual Report 2025/1](#), Section 3.2.

⁴³ [Jaguar Land Rover cyberattack cost \\$2.5 billion, says monitoring group \(therecord.media\)](#)

⁴⁴ [Ransomware behind global airport outage, says ENISA \(theregister.com\)](#)

⁴⁵ [Guidance for organisations considering payment in ransomware incidents \(ncsc.gov.uk\)](#)

3.3 Covert ORB networks in Switzerland

The growing threat posed by covert proxy networks, called Operational Relay Box (ORB) networks, has also been observed in Switzerland.⁴⁶ The number of compromised devices used in these networks is increasing. Multiple malicious activities originating from these infrastructures were identified during the reporting period, including attacks directed at Swiss systems and organisations. Furthermore, attackers can intrude unnoticed into the private lives of owners of infected devices.

An ORB network consists of compromised routers and other networked devices. These often include servers and routers belonging to individuals and small businesses, as well as infected devices from the Internet of Things (IoT). In recent years, networks that relied primarily on rented server infrastructure have become increasingly rare. Today, the most widespread and exposed ORB networks are based on a large number of compromised end devices, which are made accessible and managed via a smaller number of rented servers.

These networks are often built and operated by specialised organisations on behalf of others. They offer third parties access to the corresponding infrastructure for a fee, a model commonly referred to as proxy-network-as-a-service. This allows threat actors to effectively conceal the origin of their activities, bypass detection mechanisms, and scale their operations while keeping operational risks low. ORB networks differ from traditional criminal botnets, in particular, through their strong focus on concealment, resilience, and scalability. These features are deliberately designed to meet the requirements of advanced threat actors, including those supported by states.⁴⁷

Recommendations

ORB networks rely heavily on infected devices. Therefore, it is crucial that you take measures to reduce the risk of compromise and prevent your systems from becoming an unintended part of criminal infrastructures. The following security measures are strongly recommended:

- Promptly install security updates for devices exposed to the internet
- Enable automatic updates wherever possible
- Use strong passwords and multi-factor authentication (MFA) wherever available
- Ensure that services and open ports are only accessible from the internet when strictly necessary
- Disable Universal Plug and Play (UPnP) if it is not required

Consistently implementing these measures significantly reduces the attack surface and helps to curb the growth and effectiveness of covert proxy networks.

⁴⁶ See [Semi-Annual Report 2025/1](#), Section 8.1 and [Semi-Annual Report 2024/2](#), Section 8.1, and [IOC Extinction? China-Nexus Cyber Espionage Actors Use ORB Networks to Raise Cost on Defenders](#) (cloud.google.com)

⁴⁷ See, for example, [Semi-Annual Report 2024/2](#), Section 8.1.

4 Vulnerabilities

A vulnerability is a security weakness in an IT system. These may be flaws in the software or design, but they can also result from weak configurations, such as the use of default passwords.⁴⁸ Zero-day vulnerabilities – discovered flaws for which no vendor patch is yet available – are especially difficult to manage as attackers can exploit them before mitigation measures are in place. With growing digitalisation and the networking of devices, even the exploitation of a single vulnerability – or a chain of them – can result in data and systems being compromised.

The second half of 2025 saw a high level of activity in the area of vulnerabilities. This was particularly evident in incidents involving cyberattacks carried out via the software supply chain. Today's software products rely heavily on external program libraries and pre-built components. While this approach enables efficient development, as not every function has to be programmed from scratch, it also creates complex technical dependencies. If one of these libraries embedded in the code contains a vulnerability, all applications using that component may potentially be affected.

A notable example of this was provided by the Shai-Hulud campaigns in September and November 2025, in which attackers deliberately exploited the Node Package Manager (npm) developer platform (see Section 3.1). During the second of the two campaigns, in November 2025, several hundred npm packages were infected and subsequently distributed further via monthly downloads in the hundreds of millions. Among other things, the malware searched compromised code repositories for access credentials and published them using the victim's account.⁴⁹ For those responsible for IT security in organisations, this presents a particular challenge. Conventional inventory systems or asset management solutions typically only record the installed end application and do not list the individual third-party components it contains. Consequently, the actual risk often remains hidden and cannot be managed directly by the organisation.

This means that organisations are heavily dependent on the diligence of software vendors. They are responsible for transparently documenting the components they use and continuously checking them for vulnerabilities. Only if developers are aware of their dependencies and promptly provide updates that remediate vulnerabilities can security for end customers be ensured. Without this proactive maintenance of the supply chain, the risk to organisations remains difficult to control. Even standard vulnerabilities already pose significant challenges. During the second half of July, the NCSC became aware of widespread exploitation of a vulnerability in the SharePoint data management platform, affecting many organisations in Switzerland. Subsequent analysis by the manufacturer revealed that both state-sponsored and criminal actors were exploiting this vulnerability to access organisations with vulnerable systems (see Section 8.1).⁵⁰

⁴⁸ [Vulnerability \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/vulnerability)

⁴⁹ [Shai-Hulud 2.0 Aftermath: Trends, Victimology and Impact \(wiz.io\)](https://www.wiz.io/blog/shai-hulud-2-0-aftermath-trends-victimology-and-impact)

⁵⁰ [Disrupting active exploitation of on-premises SharePoint vulnerabilities \(microsoft.com\)](https://www.microsoft.com/en-us/security/blog/2025/07/29/disrupting-active-exploitation-of-on-premises-sharepoint-vulnerabilities/)



Recommendations

If possible, always let programs update themselves automatically. Otherwise, always use the integrated update function or download the latest version directly from the manufacturer. It is particularly important for companies to implement robust patch management processes to address vulnerabilities promptly. This requires an up-to-date inventory of your infrastructure and deployed products (SBOM⁵¹). Prioritise vulnerabilities in the parts of your infrastructure that are exposed to the internet. Carry out regular penetration tests and vulnerability scans to proactively identify potential weaknesses. Decommission software or systems that have reached their end-of-life (EOL) and are no longer supported by the vendor. If this is not possible, move them to a separate, isolated network zone. Use monitoring and threat intelligence services to respond quickly to developments. Real-time monitoring combined with automation can help you to detect attempted intrusions and anomalies promptly. Consider complementary measures, such as red-teaming exercises, regular security audits, and operating a bug bounty programme, to continuously assess and strengthen the effectiveness of your security processes.⁵²

5 Fraud and social engineering

Fraud is the deliberate deception of a person with the aim of unlawfully enriching oneself or another, causing the victim to suffer material loss.⁵³ In the online context, a particular challenge is that criminals can operate from afar – often from countries where law enforcement is difficult. Rather than relying on technically sophisticated attacks, cybercriminals typically manipulate potential victims through social engineering, prompting them to carry out steps of the fraud themselves.⁵⁴

Despite a decline from 18,269 reports in the second half of 2024 to 15,090 in the reporting period, fraud remained the dominant category among voluntary reports submitted to the NCSC. This decrease is primarily attributable to a significant reduction in fraudulent threat calls made in the name of the authorities, which have constituted a large proportion of all fraud reports since mid-2023. Reports of this type fell from 8,173 in the previous six months to 5,941 in the reporting period. While this indicates a stable downward trend, fraudulent calls still accounted for the largest proportion of reports in this category (39.4%).⁵⁵ With 1,698 reports, fraudulent lotteries conducted in the name of well-known companies remained the second most frequently reported type of fraud at 11%. These involve messages

⁵¹ [Software supply chain \(wikipedia.org\)](https://en.wikipedia.org/wiki/Software_supply_chain)

⁵² A red team is an independent group that tests an organisation's infrastructure and processes under real conditions by taking on the role of a potential attacker. The aim is to uncover and fix any existing security gaps before a real-life cyberattack can be carried out (cf. [red team \(wikipedia.org\)](https://en.wikipedia.org/wiki/Red_teaming)).

⁵³ See [Art. 146 Swiss Criminal Code](#) for a legal definition.

⁵⁴ [Social engineering \(ncsc.admin.ch\)](https://ncsc.admin.ch/social-engineering)

⁵⁵ See [Semi-Annual Report 2025/1](#), Section 5.

promising fake prizes, such as electronic devices, tools, or vouchers. These messages are often sent in the name of well-known food retailers or retail chains. The supposed winners are then directed to a website where they are asked to enter their credit card details, unwittingly taking out a subscription in the process. The third most frequently reported type of fraud was fake emails sent in the name of authorities (1,436), followed by advance-fee scams (1,243). The number of reports of fake sextortion emails declined from 1,209 in the second half of 2024 to 837 during the reporting period. However, a sustained reduction in this type of fraud is not expected, as such emails are typically sent in waves. By contrast, a growing trend was observed in fraudulent online shops. In the second half of 2025, 824 reports were recorded, which is an increase of 266 compared to the first half of the year. Notably, reports in this category tend to be concentrated between November and January, when fraudsters seek to exploit the Christmas shopping season. Conversely, reports of classified ad fraud decreased slightly from 553 in the second half of 2024 to 462 in the current reporting period, remaining relatively stable throughout the year.

Online investment fraud continued to account for the highest reported financial losses. Compared with the second half of 2024, the number of reports increased by around 100. Reporting levels remained relatively stable over the year, with 418 reports in the first half and 430 in the second half of 2025. However, follow-on fraud attempts promising the recovery of stolen funds increased significantly. While 145 reports of recovery scams were received in the first half of the year, this figure more than doubled to 325 in the second half.⁵⁶

Fraud targeting organisations

In the second half of 2025, organisations reported significantly fewer cases of CEO fraud than in the first half of the year. After reaching a record high of 605 reports in the first six months of 2025, this figure dropped to 366. Compared with the second half of 2024, reporting also declined by 68 cases. This marked decrease is largely due to the absence of fraud waves targeting schools, communes, and churches, which had been common in the first half of the year. By contrast, reports of invoice manipulation fraud (business email compromise, BEC)⁵⁷ increased again, rising from 49 cases in the second half of 2024 to 73 cases in the second half of 2025. Unlike CEO fraud, the data used in a BEC attack is not obtained from publicly available sources, but rather from compromised email accounts. These compromises are usually linked to earlier phishing attacks targeting company employees, such as chain phishing (see Section 2).⁵⁸ Once attackers have gained access to an email account, they search it for content that can be exploited. For example, when they identify customer orders or invoices, they manipulate ongoing communication with the business partner so that outstanding payments are transferred to an IBAN controlled by the attackers.

⁵⁶ See [Semi-Annual Report 2025/1](#); Section 5, paragraph on 'recovery scams following online investment fraud'.

⁵⁷ The term 'business email compromise' (BEC) is not used consistently internationally. For example, in some definitions, CEO fraud is considered a subtype of BEC (see [Business Email Compromise \(fbi.gov\)](#)). The NCSC explicitly distinguishes between the two categories, following the definition used by the Federal Office of Police (fedpol).

⁵⁸ Chain phishing involves a chain reaction of spam or phishing emails. Once an email account has been compromised, phishing emails are immediately sent to all the address book contacts.

Identity theft targeting companies

Identity theft poses a threat not only to individuals, but to companies as well. Scammers exploit the credibility associated with an established company name for their own purposes. Companies without their own website are particularly at risk. Cybercriminals work systematically. First, they search commercial registers for suitable companies. Then, they register matching domain names and create a website in the company's name. In order to appear legitimate, they copy official details, such as the address and commercial register number, of the genuine company. They then use this information to carry out various types of fraud – ranging from fake online shops to platforms offering online investment schemes. One case involved a well-established fiduciary company that had been operating for more than ten years. The perpetrators used publicly available data from the commercial register, created a corresponding website, and presented themselves to customers as the genuine company. They demanded advance payments for fiduciary services that they never provided. While the victims suffered financial losses, the legitimate company experienced considerable reputational damage as third parties mistakenly associated the fraudulent activities with it.

Fraudulent job offers

Scammers also create fake websites in the name of legitimate companies to advertise what appear to be attractive job opportunities. Since its establishment, the NCSC has regularly received reports of fake job advertisements being circulated on various platforms. Jobseekers in the hospitality sector are particularly affected, many of whom are applying from abroad. After submitting documents such as identity papers or a CV, applicants are often told almost immediately that they have been hired. Shortly afterwards, the scammers request payment for things like health insurance or registration fees, often using fake email addresses that appear to belong to the State Secretariat for Migration (SEM). Many jobseekers are unfamiliar with administrative procedures in Switzerland and therefore pay these fraudulent fees.

This type of scam does not only target applicants from abroad; people in Switzerland are also affected. The NCSC regularly receives reports of websites imitating well-known companies and misusing the names of reputable brands, such as Manor or Zalando. Jobseekers are given access to platforms operated by these fictitious companies, where they are asked to complete seemingly simple tasks in exchange for payment. These tasks may include writing product reviews or testing applications and games. The supposed earnings are displayed on the platform. To build trust, jobseekers are often initially paid a small sum. Later, however, they are pressured to pay fees to unlock higher earnings – which are never actually paid out. Jobseekers may also be asked to provide their own bank accounts or cryptocurrency wallets for transactions, which the scammers can then use, for example, to launder money. In one reported case, a victim lost almost CHF 80,000.

Recommendations

The NCSC works to have fraudulent websites taken offline as quickly as possible. However, as these sites are often hosted on servers abroad, the NCSC relies on the cooperation of foreign service providers. For this reason, companies are advised to transparently inform the public on their websites about such fraud attempts. Jobseekers often check a company's website before applying. If a warning is displayed on the legitimate site, they are more likely to recognise the fraud.



Recovery scams continue to rise

Online investment fraud currently results in the highest reported financial losses in Switzerland. However, in many cases, the fraud does not end once the initial scam has been uncovered. Instead, it is often followed by a recovery scam. Scammers contact victims again, claiming that money lost in the original investment fraud has been located as part of a criminal investigation and can now be returned. Reports of this type of follow-on fraud have more than doubled, rising from 145 in the first half of 2025 to 325 during the reporting period.

In the first half of 2025, it was observed that scammers typically impersonated law firms or authorities such as Europol, Interpol, and the Cyprus Securities and Exchange Commission.⁵⁹ In several cases, scammers posed as an employee of the NCSC, using the name of a fictitious staff member.⁶⁰ Scammers register email addresses that closely resemble those of real people working for these organisations. They also use forged documents that appear official, to increase their credibility and substantiate their fraudulent claims. In addition to email, victims are contacted by telephone, enabling scammers to adapt their approach more effectively during direct conversations. These calls are usually in English.

This approach is particularly perfidious because the follow-on losses often exceed the original damage caused by the initial online investment scam. In one reported case, a victim lost CHF 10,000 in 2023. Two years later, the scammers claimed that they could recover the money for a fee of CHF 22,000. Victims agree to such high fees because the scammers promise them a return on their investment. In this case, the alleged profit amounted to CHF 600,000.

Recommendations

Be sceptical of emails, text messages or phone calls threatening you with consequences and creating time pressure (e.g. loss of money, criminal charges, account or card blocking). Remember that criminals can easily falsify their identity through spoofing.⁶¹ Always be cautious of unusual payment requests or prize offers. All processes relating to payment transactions should be clearly regulated internally in companies. No bank or credit card company in Switzerland will ever send you an email requesting that you change your password or verify your credit card details. Bank employees will also never use security tokens or other personal e-banking or Twint credentials as a way of verifying your identity over the phone.

⁵⁹ See [Semi-Annual Report 2025/1](#); Section 5, paragraph on 'recovery scams following online investment fraud'.

⁶⁰ [Week 38: 'Daniel Bruno, NCSC, at your service' – Scammers posing as NCSC employee](#)

⁶¹ [Spoofing \(ncsc.admin.ch\)](#)

6 Attacks on the availability of websites and webservices

Attacks on the availability of websites and web services, most often in the form of distributed denial of service (DDoS), involve attackers trying to disrupt an internet-facing service by flooding it with a large volume of requests. These attacks do not, in themselves, result in unauthorised access to data, data exfiltration, or lasting damage to systems. This type of attack is particularly used for activism in cyberspace (hacktivism), to conceal other activities or for extortion.

During the second half of 2025, Switzerland did not experience any high-profile DDoS attacks linked to hacktivism. The NCSC also received no reports of DDoS extortion attempts by criminal actors. This is in contrast to the previous reporting period, when several organisations in Switzerland were targeted around major events such as the World Economic Forum (WEF) and the Eurovision Song Contest (ESC).⁶² In the second half of 2025, there were isolated reports of attempted cyberattacks, primarily targeting the financial sector, IT, and public administration. However, the impact was limited to short-term service disruptions that could be resolved using established mitigation measures.

Operation Eastwood, conducted by law enforcement authorities in mid-July 2025, temporarily reduced the activity of pro-Russian hacktivist groups.⁶³ Swiss investigators were involved in the arrests, seizures and the disruption of the group's technical infrastructure. After several weeks, the collective NoName057(16) updated its tools and resumed its disruptive activities. Shortly before Christmas, the same group claimed responsibility for attacks on the French postal service, causing delays in service. However, the French postal service did not confirm that the group was responsible.⁶⁴ In early December 2025, US authorities brought charges against members of the group, linking them to Russian state institutions.⁶⁵ Therefore, an appropriate defensive posture must also be maintained in relation to upcoming major events in and around Switzerland, to ensure the availability of online services during periods of heightened international attention.⁶⁶

With regard to attack infrastructure, attention should also be drawn to the botnet Aisuru, which has attracted global attention through DDoS attacks generating network traffic of up to 30 Tb/s. Such volumes not only push the targeted systems to their technical limits – they can also affect other parts of the internet infrastructure.⁶⁷

⁶² [Semi-Annual Report 2025/1 \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/publications/semi-annual-report-2025/1)

⁶³ [Global operation targets NoName057\(16\) pro-Russian cybercrime network – The offenders targeted Ukraine and supporting countries, including many EU Member States \(europol.europa.eu\)](https://www.europol.europa.eu/news-room/2025/07/global-operation-targets-noname05716-pro-russian-cybercrime-network-the-offenders-targeted-ukraine-and-supporting-countries-including-many-eu-member-states)

⁶⁴ [Pro-Russian hacking group claims cyberattack on France's postal service \(apnews.com\)](https://www.apnews.com/story/pro-russian-hacking-group-claims-cyberattack-on-france-s-postal-service/2025/12/15)

⁶⁵ [Office of Public Affairs | Justice Department Announces Actions to Combat Two Russian State-Sponsored Cyber Criminal Hacking Groups \(justice.gov\)](https://www.justice.gov/opa/pr/office-of-public-affairs-justice-department-announces-actions-to-combat-two-russian-state-sponsored-cyber-criminal-hacking-groups)

⁶⁶ [Cyber resilience during major events and international conferences \(ncsc.admin.ch\)](https://www.ncsc.admin.ch/ncsc/en/publications/cyber-resilience-during-major-events-and-international-conferences)

⁶⁷ [Cloudflare's 2025 Q3 DDoS threat report -- including Aisuru, the apex of botnets \(cloudflare.com\)](https://www.cloudflare.com/learning/ddos/2025-q3-ddos-threat-report/)



Recommendations

The NCSC website provides information and measures under the heading [Attack on availability \(DDoS\)](#) on how to prevent and defend against such attacks. You should work with your service provider or host to prepare for a potential attack in order to minimise the impact. For critical systems, it may be advisable to seek support from a commercial DDoS protection provider.

In the case of extortionate DDoS attacks, the NCSC recommends that you do not respond to the demands. The perpetrators may ask for more money after an initial payment and then continue with the attacks. Instead, you should report the case to the NCSC and contact the police to make a criminal complaint. In the event of an attack, see [DDoS attack – What next?](#) on the NCSC's website.

7 Data management, leaks and extortion

Data leaks and unintended data exposure are recurring topics in Switzerland and abroad. In cases where there is a downstream risk for other organisations or private individuals, data leaks can cause additional harm beyond the loss of confidentiality. For example, if a supplier experiences a breach, companies may need to monitor access to their IT infrastructure, and they also face an elevated risk of fraud attempts (see Section 5). Similarly, leaked personal information can be exploited for account takeovers, phishing (see Section 2), identity theft, or financial fraud. Data leaks play a particularly significant role in ransomware and other extortion-related attacks. Criminals will typically publish the data if no ransom is paid, or they will monetise it by selling it, for example (see Section 3.2). Poor data management within an organisation's own infrastructure, vulnerabilities (see Section 4) and technical misconfigurations can also lead to data exposure.

In the second half of 2025, people and organisations in Switzerland continued to be affected by data breaches and their sometimes long-lasting consequences. In particular, the impact of older data breaches was evident, as attackers can still use leaked data as a valuable resource years after it has been published, depending on how long the information remains valid. For example, it has been observed that attackers in Switzerland systematically reuse leaked sensitive data. By including information such as names, dates of birth or telephone numbers in emails, attackers make phishing or fake sextortion campaigns appear more credible to potential victims.

Swiss organisations were also affected by large-scale international campaigns involving data exfiltration and extortion carried out by criminal groups. One example is the incident involving Logitech.⁶⁸ Like many other companies operating internationally, Logitech was targeted in an extortion campaign by the group Clop, which exploited a zero-day vulnerability in the Oracle

⁶⁸ [Logitech Cybersecurity Disclosure \(ir.logitech.com\)](#)

E-Business Suite (EBS) to steal corporate data.⁶⁹ In Logitech's case, unauthorised access had no impact on its products or business operations. However, customer and employee data without sensitive content was exfiltrated. When the group first became active in 2019, it initially followed the classic ransomware approach involving encryption (see Section 3.2). Over time, however, the group increasingly specialised in compromising data-transfer products on a large scale and subsequently extorting business customers by threatening to publish the stolen data.⁷⁰ The Oracle EBS incident followed the same pattern. While the attack activity could be traced back to 10 July 2025, the attackers did not contact the first affected organisations until 29 September, when they emailed executives about the data breach and demanded a ransom to prevent the stolen data from being published. Unlike ransomware attacks involving encryption, this approach enables attackers to remain undetected for longer because the campaign only becomes public once they begin notifying victims. This approach can be profitable even if only a few victims pay the ransom. By repeatedly exploiting the same – still unknown – vulnerability, attackers can target many organisations while keeping the effort required for each attack relatively low.



Recommendations

Once data is on the internet, it is almost impossible to delete it entirely. Best practice is to define who may store and process which data, in what form, where it is kept, and with whom it is shared. Store only what is necessary, review data regularly, and delete anything that is no longer needed. Encrypt particularly sensitive data. Move data that must be retained but is no longer used to offline storage. Implement clear, practical processes for handling and protecting data, and ensure they are followed.

Data from previous breaches can be reused in subsequent attacks. Regularly check whether your credentials have been part of a data leak, for example using [Have I Been Pwned](#)⁷¹ or the [Identity Leak Checker from the Hasso Plattner Institute](#)⁷².

⁶⁹ [Oracle E-Business Suite Zero-Day Exploited in Widespread Extortion Campaign \(cloud.google.com\)](#)

⁷⁰ The [Semi-Annual Report 2023/1](#) highlights such a campaign (MOVEit) in Section 4.4.1 and the actor in Section 4.5.1 in detail. Other such campaigns have occurred, for example, in the context of [Accellion FTA](#), [GoAnywhere MFT](#) and [Cleo](#).

⁷¹ See [Have I Been Pwned \(haveibeenpwned.com\)](#)

⁷² See [Identity Leak Checker \(sec.hpi.de\)](#)

8 Cyberespionage and cybersabotage

State and state-affiliated actors represent a distinct type of threat in cyberspace. These groups – often referred to as advanced persistent threats (APTs) – conduct espionage operations, and more rarely sabotage, when it serves the interests of their state.⁷³ Cyberespionage is a constant challenge for Swiss counterintelligence, whereas targeted cybersabotage is usually observed only in the context of conflicts and periods of heightened geopolitical tension.⁷⁴ Unlike financially motivated cybercriminals, APTs select their targets deliberately and invest enormous resources to obtain the information they seek or to achieve the intended effect. Organisations that may be targeted need to structure their defences comprehensively against this kind of threat. Because APT groups have extensive human, technical and financial resources, they can prepare for years before carrying out an active exploitation.

8.1 Cyberespionage

As in previous years, the second half of 2025 once again demonstrated that vulnerabilities in popular enterprise software products offer appealing targets for APTs. This applies to both zero-day vulnerabilities and vulnerabilities for which a patch is available but has not yet been applied. In July 2025, Microsoft released several patches in quick succession for four vulnerabilities affecting multiple versions of its SharePoint software for on-premises SharePoint servers. The company reported that several China-based perpetrators had exploited these vulnerabilities for espionage purposes, and in some cases to distribute ransomware.⁷⁵ Microsoft also detected activity in which attackers installed additional malicious code to establish persistent, and presumably exclusive, access to compromised servers. The case attracted global attention because a number of critical infrastructure organisations were among the targets.⁷⁶ In many other cases involving vulnerabilities, however, APTs lose the opportunity for exclusive exploitation once a vulnerability becomes public. Criminal actors closely monitor vulnerability disclosures in order to identify new weaknesses that they can exploit themselves. This was observed, for example, in connection with a vulnerability in the JavaScript library React.⁷⁷

Peripheral devices (edge devices) remain an effective way for attackers to gain access to systems, either by exploiting vulnerabilities or by abusing insufficiently protected access controls. Devices that have reached the end of their product lifecycle and no longer receive security updates are particularly exposed to such attacks. The APT group Static Tundra, believed to

⁷³ [APT – Glossary \(csrc.nist.gov\)](https://csrc.nist.gov)

⁷⁴ See also press release on the situation report "[Switzerland's Security 2025](https://www.vbs.admin.ch/en/press-releases/2025/07/switzerland-s-security-2025)": [Global confrontation has direct effects on Switzerland \(vbs.admin.ch\)](https://www.vbs.admin.ch/en/press-releases/2025/07/switzerland-s-security-2025)

⁷⁵ [Disrupting active exploitation of on-premises SharePoint vulnerabilities \(microsoft.com\)](https://www.microsoft.com/en-us/security/default?cid=75422270-1047-4682-b0f8-311f041d4025)

⁷⁶ [ToolShell Attacks Hit 400+ SharePoint Servers, US Government Victims Named \(securityweek.com\)](https://www.securityweek.com/toolshell-attacks-hit-400-sharepoint-servers-us-government-victims-named/)

⁷⁷ [Multiple Threat Actors Exploit React2Shell \(CVE-2025-55182\) \(cloud.google.com\)](https://cloud.google.com/blog/topics/developers-practitioners/multiple-threat-actors-exploit-react2shell-cve-2025-55182)

be acting on behalf of Russia's military intelligence service, exploited outdated and unsupported Cisco devices in particular to compromise organisations in the telecommunications, higher education and manufacturing sectors.⁷⁸

The division of labour and specialisation commonly seen in cybercrime can also be observed among state actors. One example is the outsourcing of initial access to third parties. The French national cybersecurity agency ANSSI put forward this hypothesis after investigating attacks exploiting network devices manufactured by Ivanti. These attacks affected organisations in public administration, telecommunications, media, finance, and transport. ANSSI has established links between the activities of the threat actor Houken and China, and suspects that they have sold access to government bodies.⁷⁹

Although exploiting vulnerabilities or insecure configurations in network devices remains a preferred method, attackers also use spear-phishing emails (see Section 2) and watering hole attacks. In such attacks, the hacker group APT29 – supposedly operating on behalf of Russian intelligence services – compromised legitimate websites and redirected around 10% of visitors to a site under its control.⁸⁰

In order to maintain long-term access after the initial breach and achieve their primary objective of covert data exfiltration, attackers often install technical backdoors. One case that attracted particular attention during the reporting period was Brickstorm. According to US and Canadian authorities, Chinese state actors primarily used these backdoors in attacks targeting virtual network environments. The main targets were government infrastructure and services, as well as organisations in the IT sector.⁸¹ In an earlier report published in September, Google also identified the legal sector as a target, and emphasised that such compromises can serve as a stepping stone to other organisations.⁸²



Recommendations

Countering this type of threat requires a defence-in-depth strategy that incorporates multiple layers.⁸³ As these attackers are willing to invest considerable time and resources in developing their tools, they can identify and exploit new vulnerabilities in each target. Therefore, a successful defensive strategy must take into account different parts of the IT infrastructure. This includes the perimeter, the network, endpoints, and the human factor, as well as the organisation itself. Given the immense resources and capabilities of an APT, it is important to understand that an intrusion can never be ruled out entirely – even if an organisation has a well-

⁷⁸ [Russian state-sponsored espionage group Static Tundra compromises unpatched end-of-life network devices \(blog.talosintelligence.com\)](https://blog.talosintelligence.com/2018/08/russian-state-sponsored-espionage-group-static-tundra-compromises-unpatched-end-of-life-network-devices/)

⁷⁹ Siehe [Rapport menaces et incidents du CERT-FR \(cert.ssi.gouv.fr\)](https://cert.ssi.gouv.fr/)

⁸⁰ [Amazon disrupts watering hole campaign by Russia's APT29 \(aws.amazon.com\)](https://aws.amazon.com/blogs/news/amazon-disrupts-watering-hole-campaign-by-russias-apt29/)

⁸¹ [BRICKSTORM Backdoor \(cisa.gov\)](https://cisa.gov/brickstorm-backdoor)

⁸² [Another BRICKSTORM: Stealthy Backdoor Enabling Espionage into Tech and Legal Sectors \(cloud.google.com\)](https://cloud.google.com/blog/topics/another-brickstorm-stealthy-backdoor-enabling-espionage-into-tech-and-legal-sectors/)

⁸³ See [Minimum standard for improving ICT resilience \(ncsc.admin.ch\)](https://ncsc.admin.ch/en/section-1-6-the-defence-in-depth-concept), Section 1.6 'The defence-in-depth concept'.

established, multi-layered security plan. Network segmentation, where critical systems or sensitive data are isolated, can help prevent a compromise from spreading to all systems. For more recommendations, refer to the [ICT minimum standards](#).

8.2 Threats to industrial control systems and operational technology

Digitalisation is driving the growing use of IT in data and information management, and is increasingly affecting – and controlling – physical processes. Operational technology (OT), such as industrial control systems (ICS), which were previously often isolated, are now being networked with wider system environments and exposed to the risks that come with them. Outside the industrial sphere, this trend is most visible in building automation and smart home projects.

As far as the NCSC is aware, Switzerland was not affected by any cybersabotage attacks against industrial systems in the second half of 2025. However, internationally, the threat landscape continues to be characterised by destructive activities linked to wars and conflicts, such as the war in Ukraine and the tensions in the Middle East.⁸⁴ Outside of conflict zones, hacktivist groups have attracted attention by attempting to manipulate internet-exposed and inadequately protected operational technology (OT) systems. Authorities in the US,⁸⁵ Norway,⁸⁶ Denmark⁸⁷ and Canada⁸⁸ have identified links between these groups and the Russian state. However, the capabilities of these actors have so far been limited to relatively simple attempts at manipulation, which can be mitigated through standard security measures.⁸⁹

Attempts at cybersabotage are not limited to industrial systems; information and communication systems can also be targeted. According to the Luxembourg government, this occurred when the country's mobile network suffered a three-hour outage on 23 July 2025, which had wide-ranging effects on Luxembourgish society. The attack affected the availability of emergency numbers, and internet access and online banking services were also unavailable.⁹⁰ The disruption is believed to have been deliberate and to represent a successful attempt to infiltrate the mobile network. Media outlets announced that the attackers exploited vulnerabilities in Huawei routers, which led to the large-scale network outage.⁹¹

Vulnerabilities in industrial devices also pose a threat to OT systems, as addressing them in integrated industrial environments can be challenging. Using digital traps known as honeypots,

⁸⁴ [Sandworm hackers use data wipers to disrupt Ukraine's grain sector \(bleepingcomputer.com\)](#), [Iran-linked cyberattack reportedly disrupts public services in Albania's capital \(therecord.media\)](#)

⁸⁵ [Actions to Combat Two Russian State-Sponsored Cyber Criminal Hacking Groups \(justice.gov\)](#)

⁸⁶ [Norwegian Police Say Pro-Russian Hackers Were Likely Behind Suspected Sabotage at a Dam \(securityweek.com\)](#)

⁸⁷ [Denmark summons Russian ambassador over alleged cyberattacks on water utility \(therecord.media\)](#)

⁸⁸ [AL25-016 Internet-accessible industrial control systems \(ICS\) abused by hacktivists \(cyber.gc.ca\)](#)

⁸⁹ [Pro-Russia Hacktivists Conduct Opportunistic Attacks Against US and Global Critical Infrastructure \(cisa.gov\)](#)

⁹⁰ [Luxembourg probes reported attack on Huawei tech that caused telecoms outage \(therecord.media\)](#)

⁹¹ [Huawei, at the heart of the Post outage \(paperjam.lu\)](#)

security researchers observed attackers both exploiting older vulnerabilities and attempting to carry out disruptive control actions.⁹² The US Cybersecurity and Infrastructure Security Agency (CISA) has confirmed that vulnerabilities in systems used to control manufacturing processes have been exploited.⁹³ The growing connectivity of such systems is one factor increasing their exposure. The integration of AI into industrial processes presents an additional challenge. While this technology offers many advantages and increased efficiency, it also expands the attack surface. These systems must therefore be properly secured when integrating AI.⁹⁴



Recommendations

Secure your industrial control systems to prevent the types of attacks described in this chapter. The NCSC suggests a number of [measures to protect ICSs](#) on its website. For more comprehensive guidance, see the [minimum standards by sector](#), developed by the Federal Office for National Economic Supply (FONES) in partnership with the relevant industry bodies. Further guidance is provided by the [recommendations on OT](#)⁹⁵ from the Information Security Society Switzerland (ISSS). CISA has provided a [guidance](#)⁹⁶ for the secure use of AI in the OT environment.

⁹² [Anatomy of a Hactivist Attack: Russia-Aligned Group Targets OT/ICS \(forescout.com\)](#)

⁹³ [CISA CVE-2025-5086 to Catalog \(cisa.gov\)](#), [CISA Adds two Vulnerabilities to Catalog \(cisa.gov\)](#)

⁹⁴ [Principles for the secure integration of Artificial Intelligence in Operational Technology \(cyber.gov.au\)](#)

⁹⁵ [ISSS Operational Technology \(OT\) Empfehlungen \(cybernavi.ch\)](#)

⁹⁶ [Joint Guidance on Deploying AI Systems Securely \(cisa.gov\)](#)